

EE-482: Network Security and Cryptography

Assignment 4 Solutions

Question 1: Healthcare Organization Encryption Requirements and Policy [30 Marks]

Executive Summary

This report presents findings and recommendations for implementing encryption requirements in a small private healthcare organization's information systems. Given the sensitive nature of healthcare data and regulatory compliance requirements, a comprehensive encryption strategy is essential for protecting patient information and maintaining organizational integrity.

Current Healthcare Data Security Landscape

Healthcare organizations face unique challenges in data security due to:

- **Regulatory Compliance:** HIPAA, HITECH Act, and other healthcare regulations
- **Patient Privacy:** Protection of Personal Health Information (PHI)
- **Data Sensitivity:** Medical records, financial information, and personal identifiers
- **System Interconnectivity:** EMR systems, billing platforms, and communication networks

Encryption Requirements Analysis

1. Data Classification and Protection Needs

Highly Sensitive Data (Requiring Strong Encryption):

- Patient medical records and PHI
- Financial and billing information
- Authentication credentials
- Communication between healthcare providers

Moderately Sensitive Data:

- Administrative documents
- Non-patient operational data
- System logs and audit trails

2. Encryption Implementation Areas

Data at Rest:

- Database encryption for patient records
- File system encryption for servers and workstations
- Backup and archive encryption
- Mobile device encryption

Data in Transit:

- Network communications (TLS/SSL)
- Email encryption for PHI transmission
- VPN connections for remote access
- API communications between systems

Data in Use:

- Application-level encryption
- Memory protection mechanisms
- Secure processing environments

Technical Recommendations

1. Encryption Standards and Algorithms

Symmetric Encryption:

- AES-256 for data at rest
- AES-128/256 for high-performance applications
- ChaCha20-Poly1305 for mobile devices

Asymmetric Encryption:

- RSA-2048 minimum, RSA-4096 preferred
- ECC P-256 for mobile and IoT devices
- Ed25519 for digital signatures

Hashing and Integrity:

- SHA-256 for general purposes

- SHA-3 for new implementations
- HMAC for message authentication

2. Key Management Strategy

Key Generation:

- Hardware Security Modules (HSMs) for critical keys
- Cryptographically secure random number generators
- Regular key rotation schedules

Key Storage:

- Dedicated key management systems
- Hardware-backed key storage
- Separation of encryption keys from encrypted data

Key Distribution:

- Secure key exchange protocols
- Certificate-based authentication
- Multi-factor authentication for key access

Implementation Framework

Phase 1: Critical Systems (Months 1-3)

- EMR system encryption
- Database encryption implementation
- Network communication security (TLS)
- Email encryption for PHI

Phase 2: Infrastructure Hardening (Months 4-6)

- Workstation and server encryption
- Backup system encryption
- Mobile device management and encryption
- VPN implementation for remote access

Phase 3: Advanced Security (Months 7-9)

- Application-level encryption
- Advanced threat protection
- Security monitoring and logging
- Staff training and awareness programs

Policy Framework

1. Encryption Policy Structure

Policy Governance:

- Chief Information Security Officer (CISO) oversight
- Regular policy reviews and updates
- Compliance monitoring and reporting
- Incident response procedures

Technical Standards:

- Approved encryption algorithms and key lengths
- Key management procedures
- Implementation guidelines
- Exception handling processes

2. Compliance and Audit Requirements

Regular Assessments:

- Annual encryption audits
- Penetration testing
- Vulnerability assessments
- Compliance reporting

Documentation Requirements:

- Encryption inventory and mapping
- Key management documentation
- Incident logs and responses
- Training records

Risk Assessment and Mitigation

High-Risk Scenarios:

- Data breaches involving unencrypted PHI
- Insider threats and unauthorized access
- System compromises and malware
- Physical theft of devices and media

Mitigation Strategies:

- Defense-in-depth approach
- Regular security awareness training
- Incident response planning
- Business continuity and disaster recovery

Budget and Resource Considerations

Initial Investment:

- Encryption software and hardware: \$50,000-\$100,000
- Implementation and consulting: \$30,000-\$50,000
- Staff training and certification: \$10,000-\$20,000

Ongoing Costs:

- Annual software licensing: \$15,000-\$25,000
- Maintenance and support: \$10,000-\$15,000
- Compliance auditing: \$5,000-\$10,000

Conclusion and Recommendations

The healthcare organization should implement a comprehensive encryption strategy focusing on:

1. **Immediate Priority:** Encrypt all PHI data at rest and in transit
2. **Technical Implementation:** Deploy AES-256 encryption with robust key management
3. **Policy Development:** Establish clear encryption policies and procedures
4. **Staff Training:** Ensure all personnel understand encryption requirements
5. **Continuous Monitoring:** Regular audits and compliance assessments

This approach will ensure regulatory compliance, protect patient privacy, and maintain the organization's reputation while providing a scalable foundation for future growth.

Question 2: Public Key Infrastructure (PKI) Analysis [20 Marks]

The PKI Debate: Authentication vs. Encryption

Both James and Alexander have partial understanding of PKI, but neither is completely correct. PKI is neither simply an authentication mechanism nor just an encryption algorithm—it is a comprehensive framework that encompasses both authentication and encryption capabilities.

What is Public Key Infrastructure (PKI)?

PKI is a comprehensive framework of policies, procedures, hardware, software, and cryptographic protocols used to create, manage, distribute, store, and revoke digital certificates and manage public-key encryption. It serves multiple security functions:

Core Functions of PKI:

1. Authentication:

- Verifies the identity of users, devices, and services
- Ensures that entities are who they claim to be
- Provides non-repudiation through digital signatures

2. Encryption:

- Enables secure communication through public-key cryptography
- Protects data confidentiality in transit and at rest
- Facilitates secure key exchange for symmetric encryption

3. Integrity:

- Ensures data has not been tampered with
- Provides digital signatures for document authenticity
- Maintains trust in digital transactions

4. Authorization:

- Controls access to resources based on verified identities
- Enables role-based access control
- Supports privilege management

Certificate Authority (CA)

A Certificate Authority is a trusted third-party organization that:

Primary Responsibilities:

- **Issues Digital Certificates:** Creates and signs certificates after verifying identities
- **Maintains Certificate Lifecycle:** Manages certificate renewal, revocation, and expiration
- **Publishes Certificate Revocation Lists (CRLs):** Maintains lists of revoked certificates
- **Root of Trust:** Serves as the foundation of trust in the PKI ecosystem

Types of Certificate Authorities:

- **Root CA:** Top-level authority in the trust hierarchy
- **Intermediate CA:** Subordinate CAs that issue certificates under root CA authority
- **Registration Authority (RA):** Handles certificate registration and verification processes

CA Trust Model:

- **Hierarchical Model:** Tree-like structure with root CA at the top
- **Cross-Certification:** Multiple CAs certify each other
- **Bridge CA:** Central authority that connects multiple PKI domains

Digital Certificates

Digital certificates are electronic documents that bind a public key to an identity using digital signatures.

Certificate Components:

Standard Fields (X.509 format):

- **Subject:** Entity the certificate is issued to
- **Issuer:** CA that issued the certificate
- **Public Key:** The entity's public key
- **Serial Number:** Unique identifier for the certificate
- **Validity Period:** Certificate's valid date range
- **Digital Signature:** CA's signature to ensure authenticity

Extended Information:

- **Subject Alternative Names:** Additional identities (email, DNS names)
- **Key Usage:** Defines how the public key can be used

- **Certificate Policies:** Policies under which certificate was issued
- **Authority Key Identifier:** Links to issuing CA's public key

Types of Digital Certificates:

SSL/TLS Certificates:

- Secure web communications (HTTPS)
- Domain validation, organization validation, extended validation
- Wildcard and multi-domain certificates

Code Signing Certificates:

- Verify software authenticity and integrity
- Prevent tampering with executable code
- Enable trusted software distribution

Email Certificates:

- Secure email communication (S/MIME)
- Email encryption and digital signatures
- Personal and organizational email protection

Client Authentication Certificates:

- User authentication to systems and applications
- Two-factor authentication implementation
- Access control and identity verification

PKI Implementation Architecture

Core Components:

- **Certification Authority (CA):** Issues and manages certificates
- **Registration Authority (RA):** Handles certificate requests and identity verification
- **Certificate Repository:** Stores and distributes certificates
- **Certificate Revocation Infrastructure:** Manages revoked certificates
- **End-Entity Applications:** Software that uses PKI services

Security Considerations:

- **Private Key Protection:** Hardware security modules (HSMs)
- **Certificate Validation:** Real-time certificate status checking
- **Key Escrow:** Secure backup of encryption keys
- **Audit and Compliance:** Comprehensive logging and monitoring

Conclusion: Resolving the Debate

James's Position (Authentication Focus): Partially correct—PKI does provide robust authentication mechanisms through digital certificates and identity verification.

Alexander's Position (Encryption Algorithm): Partially correct—PKI enables encryption through public-key cryptography and secure key management.

Complete Truth: PKI is a comprehensive security infrastructure that provides authentication, encryption, digital signatures, and key management services. It's not limited to either authentication or encryption but serves as a foundation for multiple security services in digital environments.

PKI's true value lies in its ability to create a trusted environment where entities can securely communicate, authenticate, and conduct digital transactions with confidence in the security and authenticity of their interactions.